

SEGURIDAD EN EL DESARROLLO DE APLICACIONES

PRACTICA 3.2 — DAST

OWASP ZAP contra aplicacion .NET Core 10

Valeria Hernández Cortés — IDGS17

1. OBJETIVO

Ejecutar DAST con OWASP ZAP contra el proyecto ASP.NET Core 10 vulnerable de practicas anteriores, en un entorno Docker completamente aislado, documentar los hallazgos con CVSS y CWE, verificar que las correcciones de P2 eliminan los hallazgos, e integrar ZAP en el pipeline GitHub Actions.

2. FASE 1 — PREPARACION DEL ENTORNO

2.1 Red Docker aislada

Crea una red Docker privada para que ZAP y la app vulnerable se comuniquen sin exponerse al host:

Red Docker aislada

```
C:\Users\valec\OneDrive\Documentos\git>docker network create --internal pentest-net
5cc52714ce35c73e109f2282f6b63a0f0303ebc59580d18a132c65b471bc3860
```

```
C:\Users\valec\OneDrive\Documentos\git>docker network inspect pentest-net
[
  {
    "Name": "pentest-net",
    "Id": "5cc52714ce35c73e109f2282f6b63a0f0303ebc59580d18a132c65b471bc3860",
    "Created": "2026-07-23T03:08:06.702659615Z",
    "Scope": "local",
    "Driver": "bridge",
    "EnableIPv4": true,
    "EnableIPv6": false,
    "IPAM": {
      "Driver": "default",
      "Options": {},
      "Config": [
        {
          "Subnet": "172.20.0.0/16",
          "Gateway": "172.20.0.1"
        }
      ]
    },
    "Internal": true,
    "Attachable": false,
    "Ingress": false,
    "ConfigFrom": {
      "Network": ""
    },
    "ConfigOnly": false,
    "Options": {
      "com.docker.network.enable_ipv4": "true",
      "com.docker.network.enable_ipv6": "false"
    }
  }
]
```

2.2 docker-compose para el entorno de pruebas

Ambos contenedores en estado 'running'

```
#16 resolving provenance for metadata file
#16 DONE 0.1s
[+] up 2/2
  Image vulnerableapp-vulnerable_app Built
[+] up 4/4 vulnerableapp_pentest-net Created
  Image vulnerableapp-vulnerable_app Built
  Network vulnerableapp_pentest-net Created
  Container vulnerable_app Started
  Container zap Started
```

```
[+] up 1/1
  Image vulnerableapp-vulnerable_app Built
sg="Found orphan containers (grafana, promtail, loki) for this project. [+] up 3/3oved or renamed this service in your compose file, you can run this command with the -
-remove-orphans flag to
  Image vulnerableapp-vulnerable_app Built
238.4s Container zap Started
0.7s Container vulnerable_app Started
```

3. FASE 2 — ESCANEO PASIVO Y ACTIVO CON ZAP

3.1 Escaneo pasivo (baseline scan)

Ejecutar desde el contenedor ZAP

```
C:\Users\valec\OneDrive\Documentos\git\VulnerableApp>docker exec zap zap-baseline.py -t http://vulnerable_app:8080 -r baseline-report.html -x baseline-report.xml -J bas
eline-report.json -l WARN
Total of 4 URLs
WARN-NEW: Missing Anti-clickjacking Header [10020] x 2
http://vulnerable_app:8080/ (200 OK)
http://vulnerable_app:8080 (200 OK)
WARN-NEW: X-Content-Type-Options Header Missing [10021] x 2
http://vulnerable_app:8080/ (200 OK)
http://vulnerable_app:8080 (200 OK)
WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 2
http://vulnerable_app:8080/ (200 OK)
http://vulnerable_app:8080 (200 OK)
FAIL-NEW: 0 FAIL-INPROG: 0 WARN-NEW: 3 WARN-INPROG: 0 INFO: 0 IGNORE: 0 PASS: 57
```

Ver reporte generado

ls ./zap-reports/

```
C:\Users\valec\OneDrive\Documentos\git\VulnerableApp>dir .\zap-reports
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 2689-DF85

Directorio de C:\Users\valec\OneDrive\Documentos\git\VulnerableApp\zap-reports
22/07/2026 11:57 p. m. <DIR> .
22/07/2026 11:57 p. m. <DIR> ..
22/07/2026 11:57 p. m. 31,415 baseline-report.html
22/07/2026 11:57 p. m. 7,101 baseline-report.json
22/07/2026 11:57 p. m. 8,356 baseline-report.xml
3 archivos 46,872 bytes
2 dirs 166,801,182,720 bytes libres
```

baseline-report.html baseline-report.xml baseline-report.json

Risk Level	Number of Alerts
High	0
Medium	4
Low	1
Informational	0
False Positives	0

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	2
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-inline	Medium	2
CSP: style-src unsafe-inline	Medium	2
X-Content-Type-Options Header Missing	Low	2

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://vulnerable_app:8080
Node Name	http://vulnerable_app:8080
Method	GET

3.2 Escaneo activo completo

El escaneo activo envia payloads reales (SQLi, XSS, etc.). Puede tardar 10-30 minutos segun la app:

```
c:\Users\valec\OneDrive\Documents\git\VulnerableApp>docker exec zap zap-full-scan.py -t http://vulnerable_app:8080 -r fullscan-report.html -x fullscan-report.xml -J fullscan-report.json -m 5 -i
Total of 4 URLs
PASS: Directory Browsing [0]
PASS: Vulnerable JS Library (Powered by Retire.js) [10003]
PASS: Swagger UI Secret & Vulnerability Detector [100043]
PASS: In Page Banner Information Leak [10009]
PASS: Cookie No HttpOnly Flag [10010]
PASS: Cookie Without Secure Flag [10011]
PASS: Re-examine Cache-control Directives [10015]
PASS: Cross-Domain JavaScript Source File Inclusion [10017]
PASS: Content-Type Header Missing [10019]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: Information Disclosure - Suspicious Comments [10027]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
PASS: Strict-Transport-Security Header [10035]
PASS: HTTP Server Response Header [10036]
PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]
PASS: X-Backend-Server Header Information Leak [10039]
PASS: Secure Pages Include Mixed Content [10040]
PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]
PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]
PASS: User Controllable JavaScript Event (XSS) [10043]
PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]
PASS: Source Code Disclosure - /WEB-INF Folder [10045]
PASS: HTTPS Content Available via HTTP [10047]
```

Ver reporte:

```
# fullscan-report.html contendra todos los hallazgos
```

3.3 Escaneo de API REST

Si tu app expone endpoints API, ZAP puede usar la especificacion OpenAPI para un escaneo mas preciso:

Escaneo de API con definicion OpenAPI

```
C:\Users\valec\OneDrive\Documents\git\VulnerableApp>docker exec zap zap-api-scan.py -t http://vulnerable_app:8080/swagger/v1/swagger.json -f openapi -r api-report.html
-J api-report.json
2026-07-23 06:22:43,092 Number of Imported URLs: 8
Total of 42 URLs
PASS: Directory Browsing [0]
PASS: Vulnerable JS Library (Powered by Retire.js) [10003]
PASS: Swagger UI Secret & Vulnerability Detector [100043]
PASS: In Page Banner Information Leak [10009]
PASS: Cookie No HttpOnly Flag [10010]
PASS: Cookie Without Secure Flag [10011]
PASS: Re-examine Cache-control Directives [10015]
PASS: Cross-Domain JavaScript Source File Inclusion [10017]
PASS: Content-Type Header Missing [10019]
PASS: Anti-clickjacking Header [10020]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: Information Disclosure - Suspicious Comments [10027]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
```

Risk Level	Number of Alerts
High	0
Medium	4
Low	1
Informational	0
False Positives:	0

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	2
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-inline	Medium	2
CSP: style-src unsafe-inline	Medium	2
X-Content-Type-Options Header Missing	Low	2

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://vulnerable_app:8080
Node Name	http://vulnerable_app:8080
Method	GET

4. FASE 3 — ANALISIS Y DOCUMENTACION DE HALLAZGOS

4.1 Tabla de hallazgos

Para cada hallazgo con riesgo High o Medium del fullscan-report.html, completa:

#	Nombre del hallazgo	Riesgo ZAP	CWE	CVSS estimado	URL afectada	Evidencia	Remediación propuesta
1	CSP: Failure to Define Directive with No Fallback	Medium	CWE-693: Protection Mechanism Failure	4.3	http://vulnerable_app:8080/	La directiva form-action (entre otras) no tiene fallback a default-src y la evidencia muestra solo frame-ancestors 'none';.	Configurar una política CSP completa en las cabeceras HTTP del servidor, definiendo directivas como default-src, script-src, style-src e img-src con valores restrictivos para evitar la carga de contenido no autorizado.
2	CSP: Wildcard Directive	Medium	CWE-693: Protection Mechanism Failure	5.4 CVSS: 3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N	http://vulnerable_app:8080/	Directivas como script-src, style-src, img-src permiten orígenes comodín (wildcard) o no están definidas, mostrando solo frame-ancestors 'none';	Restringir las fuentes permitidas en la cabecera Content-Security-Policy, evitando el uso de comodines y especificando únicamente dominios confiables para cada tipo de recurso.
3	CSP: script-src unsafe-inline	Medium	CWE-693: Protection Mechanism Failure	6.1 CVSS: 3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	http://vulnerable_app:8080/	La directiva script-src incluye unsafe-inline, mientras la política actual solo refleja frame-ancestors 'none'.	Eliminar la directiva unsafe-inline de script-src y utilizar mecanismos más seguros como nonce o hashes para permitir únicamente scripts autorizados.

4	CSP: style-src unsafe-inline	Medium	CWE-693: Protection Mechanism Failure	4.3CVSS: 3.1/AV:N/ AC:L/PR: N/UI:R/S: U/C:N/I:L/ A:N	http://vulnerable_app:8080/	La directiva style-src incluye unsafe-inline, y la evidencia muestra solo frame-ancestors 'none';.	Remover unsafe-inline de style-src y definir fuentes de estilos permitidas de forma explícita para reducir riesgos asociados con la inyección de contenido malicioso.
---	------------------------------------	--------	--	---	---	--	---

4.2 Analisis de un hallazgo en detalle

1. Nombre del hallazgo y tipo segun OWASP Top 10: *CSP: script-src unsafe-inline.*

Pertenece a la categoría A05: Security Misconfiguration, falta endurecer las reglas de seguridad de la aplicación

2. Request HTTP exacto que ZAP envio para detectarlo (del reporte XML):

GET / HTTP/1.1

Host: vulnerable_app:8080

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,/*;q=0.8*

3. Response HTTP que revelo la vulnerabilidad.

El problema está en lo que contestó nuestro servidor. Según el reporte, la única regla de seguridad que mandamos en la cabecera fue esta:

HTTP/1.1 200 OK

Content-Type: text/html; charset=utf-8

Content-Security-Policy: frame-ancestors 'none';

4. Por que esta respuesta confirma la vulnerabilidad (explica el mecanismo).

La ausencia de la cabecera Content-Security-Policy esta incompleta, le indica al navegador web que confie plenamente en cualquier sitio que intente incrustar esta aplicación. Esto significa que la aplicación permite ser renderizada dentro de etiquetas <iframe>, <frame> u <object> provenientes de dominios de terceros no autorizados.

5. Que datos o accesos podria obtener un atacante real. El atacante puede cargar la aplicación

Si un atacante aprovecha esto y logra inyectar su propio código JavaScript en la página, el navegador de nuestro usuario lo va a ejecutar sin dudar. Esto significa que el atacante podría robarse las cookies de sesión , alterar completamente el diseño de la interfaz para engañarlos, o redirigirlos a una página falsa.

Codigo correcto que elimina la vulnerabilidad.

```
app.Use(async (context, next) =>
{
    // Configuramos una política estricta que bloquea scripts en línea (unsafe-inline)
    // y solo permite cargar recursos y scripts de nuestro propio dominio ('self').
    // Además, mantenemos la regla de frame-ancestors 'none' que ya teníamos.
    context.Response.Headers.Append("Content-Security-Policy", "default-src 'self'; script-src 'self';
frame-ancestors 'none';");

    await next();
});
```

4.3 Verificar que las correcciones de P2 funcionan

Aplica las correcciones del código que hiciste en prácticas anteriores (SQL parameterizado, Html.Encode, validación de entrada). Recompila el contenedor y ejecuta el baseline scan de nuevo:

Re-escaneo post-corrección


```
C:\Users\valec\OneDrive\Documentos\git\VulnerableApp>docker compose -f pentest-compose.yml build vulnerable_app
#1 [internal] load local bake definitions
#1 reading from stdin 613B 0.0s done
#1 DONE 0.0s

#2 [internal] load build definition from Dockerfile
#2 transferring dockerfile: 460B 0.0s done
#2 DONE 0.1s
```

Re-escanear

Generated on Thu, 23 Jul 2026 06:05:06

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	1
Informational	0
False Positives:	0

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	2
Missing Anti-clickjacking Header	Medium	2
X-Content-Type-Options Header Missing	Low	2

Alert Detail

Compara baseline-report.html (antes) con baseline-after-fix.html (despues). Documenta que hallazgos desaparecieron y cuales persisten con justificacion.

Hallazgos que desaparecieron

- CSP: Failure to Define Directive with No Fallback
- CSP: Wildcard Directive
- CSP: script-src unsafe-inline
- CSP: style-src unsafe-inline

Estos errores desaparecieron porque en el primer escaneo la aplicación sí estaba enviando una cabecera de seguridad, pero estaba incompleta (solo contenía frame-ancestors 'none';). Al realizar los cambios en el código para el segundo escaneo, esa cabecera incompleta se eliminó por completo. Como ya no hay una cabecera CSP presente, ZAP ya no puede evaluar si sus reglas internas (como los comodines o los scripts en línea) están mal configuradas.

Hallazgos que persisten

- X-Content-Type-Options Header Missing (Riesgo Bajo): Este hallazgo persiste. Aparecía en el primer reporte y sigue apareciendo en el segundo con exactamente 2 instancias.

Justificación: El código que agregamos no incluyó la instrucción para que el servidor devuelva la cabecera X-Content-Type-Options: nosniff en las respuestas HTTP.

- Content Security Policy (CSP) Header Not Set (Riesgo Medio): Esta alerta es nueva en el segundo reporte.

Justificación: Como mencionamos antes, al quitar la regla parcial de CSP que teníamos, ZAP ahora detecta que la aplicación no tiene absolutamente ninguna política de seguridad de contenido configurada.

- Missing Anti-clickjacking Header (Riesgo Medio): Esta alerta también es nueva en el segundo reporte.

Justificación: En el primer escaneo teníamos la regla frame-ancestors 'none'; que nos protegía contra el clickjacking. Al desaparecer esa regla en nuestro nuevo código, ZAP nos advierte que nuestra aplicación vuelve a ser vulnerable a ser incrustada en iframes maliciosos, ya que nos falta tanto X-Frame-Options como un CSP válido.

5. FASE 4 — ZAP EN GITHUB ACTIONS

5.1 Workflow DAST automatizado

```
C:\Users\valec\OneDrive\Documentos\git>tree /f .github
Listado de rutas de carpetas
El número de serie del volumen es 000000E1 2689:DF85
C:\USERS\VALEC\ONEDRIVE\DOCUMENTOS\GIT\GITHUB
├── workflows
│   └── security.yml
```

5.2 Archivo de reglas ZAP (.zap/rules.tsv)

```
C:\Users\valec\OneDrive\Documentos\git>tree /f .zap
Listado de rutas de carpetas
El número de serie del volumen es 00000047 2689:DF85
C:\USERS\VALEC\ONEDRIVE\DOCUMENTOS\GIT\ZAP
└── rules.tsv
```

5. Conclusión

La realización de esta práctica permitió comprobar la importancia de incorporar pruebas de seguridad dinámicas dentro del proceso de desarrollo de aplicaciones utilizando OWASP ZAP en un entorno Docker aislado. A través del análisis realizado, se identificó que una aplicación no solo debe cumplir con los requerimientos funcionales, sino también implementar mecanismos de protección que reduzcan los riesgos de seguridad durante la comunicación entre el servidor y los usuarios.

El desarrollo de aplicaciones modernas requiere integrar buenas prácticas de programación y medidas de ciberseguridad desde las primeras etapas del ciclo de vida del software. Asimismo, el análisis comparativo entre el estado inicial y posterior a la aplicación de correcciones permitió comprender la importancia de validar continuamente los cambios realizados en la configuración de seguridad. Una modificación aparentemente sencilla puede afectar controles previamente implementados, por lo que es necesario realizar pruebas constantes para garantizar que las medidas

de protección permanezcan activas.

Finalmente, la integración de los análisis de seguridad automatizados mediante GitHub Actions demuestra la utilidad de incorporar herramientas DAST dentro de los procesos de integración continua. Esto permite detectar posibles fallos de seguridad de manera temprana, mejorar la calidad del software y asegurar que las nuevas versiones de la aplicación mantengan estándares adecuados de protección.